Merged vulnerability report
29 finding(s)

Finding 1
  Scanner: Nikto
  Title:
    - Apache allows directory listings by requesting.
    - Apache allows directory listings.
  Site URL:
    - 127.0.0.1:80/dvwa/?D=A
    - 127.0.0.1:80/dvwa/?N=D
    - 127.0.0.1:80/dvwa/?S=A
    - 127.0.0.1:80/dvwa/?M=A
  Method: GET
  Description:
    - Apache allows directory listings by requesting.
    - Apache allows directory listings. Upgrade Apache or disable directory indexing.
  References: CVE-2001-0731
  Composite Score: 2.8378

Finding 2
  Scanner: ZAP
  Title: Cookie without SameSite Attribute
  Site URL: http://localhost:4280
  Method: GET
  Description: A cookie has been set without the SameSite attribute, which means that the cookie can
      be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter
      measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
  References: https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
  Composite Score: 2.5

Finding 3
  Scanner: Nikto
  Title: /images: The web server may reveal its internal or real IP in the Location header via a
      request to with HTTP/1.0.
  Site URL: 127.0.0.1:80/dvwa/images
  Method: GET
  Description: /images: The web server may reveal its internal or real IP in the Location header via
      a request to with HTTP/1.0. The value is "172.17.0.2".
  References: CVE-2000-0649
  Composite Score: 1.99051

Finding 4
  Scanner: Nikto
  Title: The remote server may allow directory listings through Web Publisher by forcing the server
      to show all files via 'open directory browsing'.
  Site URL:
    - 127.0.0.1:80/dvwa/?PageServices
    - 127.0.0.1:80/dvwa/?wp-cs-dump
  Method: GET
  Description: The remote server may allow directory listings through Web Publisher by forcing the
      server to show all files via 'open directory browsing'. Web Publisher should be disabled.
  References: CVE-1999-0269
  Composite Score: 0.2532

Finding 5
  Scanner: Nikto
  Title: Abyss 1.03 reveals directory listing when multiple /'s are requested.
  Site URL: 127.0.0.1:80/dvwa//
      //
      //
  Method: GET
  Description: Abyss 1.03 reveals directory listing when multiple /'s are requested.
  References: CVE-2002-1078
  Composite Score: 0.13795

Finding 6
  Scanner: ZAP
  Title: Content Security Policy (CSP) Header Not Set
  Site URL:
    - http://localhost:4280
    - http://localhost:4280/login.php
    - http://localhost:4280/sitemap.xml
  Method: GET
  Description: Content Security Policy (CSP) is an added layer of security that helps to detect and

```
      mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection
      attacks. These attacks are used for everything from data theft to site defacement or
      distribution of malware. CSP provides a set of standard HTTP headers that allow website owners
      to declare approved sources of content that browsers should be allowed to load on that page —
      covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as
      Java applets, ActiveX, audio and video files.
  References:
    - https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
    - https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
    - https://www.w3.org/TR/CSP/
    - https://w3c.github.io/webappsec-csp/
    - https://web.dev/articles/csp
    - https://caniuse.com/#feat=contentsecuritypolicy
    - https://content-security-policy.com/
  Composite Score: 0.10585

Finding 7
  Scanner: ZAP
  Title: X-Content-Type-Options Header Missing
  Site URL:
    - http://localhost:4280
    - http://localhost:4280/dvwa/css/login.css
    - http://localhost:4280/dvwa/images/login_logo.png
    - http://localhost:4280/login.php
    - http://localhost:4280/robots.txt
  Method: GET
  Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This
      allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response
      body, potentially causing the response body to be interpreted and displayed as a content type
      other than the declared content type. Current (early 2014) and legacy versions of Firefox will
      use the declared content type (if one is set), rather than performing MIME-sniffing.
  References:
    - https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/com
      patibility/gg622941(v=vs.85)
    - https://owasp.org/www-community/Security_Headers
  Composite Score: 0.10585

Finding 8
  Scanner:
    - Nikto
    - ZAP
  Title:
    - X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP
      header with the frame-ancestors directive.
    - Missing Anti-clickjacking Header
  Site URL:
    - 127.0.0.1:80/dvwa/
    - http://localhost:4280
    - http://localhost:4280/login.php
  Method: GET
  Description:
    - X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP
      header with the frame-ancestors directive.
    - The response does not protect against 'ClickJacking' attacks. It should include either
      Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
  Composite Score: 0.04938

Finding 9
  Scanner: ZAP
  Title: HTTP Only Site
  Site URL: http://localhost:4280/
  Method: GET
  Description: The site is only served under HTTP and not HTTPS.
  References:
    - https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html
    - https://letsencrypt.org/
  Composite Score: 0.04621

Finding 10
  Scanner: ZAP
  Title: Parameter Tampering
  Site URL: http://localhost:4280/login.php
  Method: POST
  Description: Parameter manipulation caused an error page or Java stack trace to be displayed. This
```

```
      indicated lack of exception handling and potential areas for further exploit.
  References: -
  Composite Score: 0.02689

Finding 11
  Scanner: ZAP
  Title: In Page Banner Information Leak
  Site URL: http://localhost:4280/sitemap.xml
  Method: GET
  Description: The server returned a version banner string in the response content. Such information
      leaks may allow attackers to further target specific issues impacting the product and version
      in use.
  References: https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Securit
      y_Testing/08-Testing_for_Error_Handling/
  Composite Score: 0.01426

Finding 12
  Scanner: ZAP
  Title:
    - Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
    - Server Leaks Version Information via "Server" HTTP Response Header Field
  Site URL:
    - http://localhost:4280
    - http://localhost:4280/
    - http://localhost:4280/login.php
    - http://localhost:4280/dvwa/css/login.css
    - http://localhost:4280/dvwa/images/login_logo.png
    - http://localhost:4280/robots.txt
  Method:
    - GET
    - POST
  Description:
    - The web/application server is leaking information via one or more "X-Powered-By" HTTP response
      headers. Access to such information may facilitate attackers identifying other
      frameworks/components your web application is reliant upon and the vulnerabilities such
      components may be subject to.
    - The web/application server is leaking version information via the "Server" HTTP response
      header. Access to such information may facilitate attackers identifying other vulnerabilities
      your web/application server is subject to.
  References:
    - https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testin
      g/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
    - https://www.troyhunt.com/shhh-dont-let-your-response-headers/
    - https://httpd.apache.org/docs/current/mod/core.html#servertokens
    - https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
  Composite Score: 0.01426

Finding 13
  Scanner: ZAP
  Title: Authentication Request Identified
  Site URL: http://localhost:4280/login.php
  Method: POST
  Description: The given request has been identified as an authentication request. The 'Other Info'
      field contains a set of key=value lines which identify any relevant fields. If the request is
      in a context which has an Authentication Method set to "Auto-Detect" then this rule will
      change the authentication to match the request identified.
  References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
  Composite Score: 0.0

Finding 14
  Scanner: ZAP
  Title: Session Management Response Identified
  Site URL:
    - http://localhost:4280
    - http://localhost:4280/login.php
  Method:
    - GET
    - POST
  Description: The given response has been identified as containing a session management token. The
      'Other Info' field contains a set of header tokens that can be used in the Header Based
      Session Management Method. If the request is in a context which has a Session Management
      Method set to "Auto-Detect" then this rule will change the session management to use the
      tokens identified.
  References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
  Composite Score: 0.0
```

```
Finding 15
  Scanner: ZAP
  Title: User Agent Fuzzer
  Site URL:
    - http://localhost:4280
    - http://localhost:4280/
    - http://localhost:4280/dvwa
    - http://localhost:4280/dvwa/css
    - http://localhost:4280/dvwa/images
  Method: GET
  Description: Check for differences in response based on fuzzed User Agent (eg. mobile sites,
      access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the
      response body with the original response.
  References: https://owasp.org/wstg
  Composite Score: 0.0

Finding 16
  Scanner: Nikto
  Title: Directory indexing found.
  Site URL:
    - 127.0.0.1:80/dvwa/
    - 127.0.0.1:80/dvwa/./
    - 127.0.0.1:80/dvwa//
    - 127.0.0.1:80/dvwa/%2e/
    - 127.0.0.1:80/dvwa///
    - 127.0.0.1:80/dvwa/css/
    - 127.0.0.1:80/dvwa/includes/
    - 127.0.0.1:80/dvwa/images/
    - 127.0.0.1:80/dvwa/////////////////////////////////////////////////////////////////////////
      ////////////////////////////////////////////////////////////////////////////////////////
      ////////////////////////////////////////////////////////////////////////////
  Method: GET
  Description: Directory indexing found.
  References: CWE-548
  Composite Score: -1

Finding 17
  Scanner: Nikto
  Title: OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
  Site URL: 127.0.0.1:80/dvwa/
  Method: OPTIONS
  Description: OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
  References: -
  Composite Score: -1

Finding 18
  Scanner: Nikto
  Title: RFC-1918 IP address found in the 'location' header.
  Site URL: 127.0.0.1:80/dvwa/images
  Method: GET
  Description: RFC-1918 IP address found in the 'location' header. The IP is "172.17.0.2".
  References: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
  Composite Score: -1

Finding 19
  Scanner: Nikto
  Title: Suggested security header missing: content-security-policy.
  Site URL: 127.0.0.1:80/dvwa/
  Method: GET
  Description: Suggested security header missing: content-security-policy.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
  Composite Score: -1

Finding 20
  Scanner: Nikto
  Title: Suggested security header missing: referrer-policy.
  Site URL: 127.0.0.1:80/dvwa/
  Method: GET
  Description: Suggested security header missing: referrer-policy.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
  Composite Score: -1

Finding 21
  Scanner: Nikto
```

```
  Title: Suggested security header missing: strict-transport-security.
  Site URL: 127.0.0.1:80/dvwa/
  Method: GET
  Description: Suggested security header missing: strict-transport-security.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
  Composite Score: -1

Finding 22
  Scanner: Nikto
  Title: Suggested security header missing: permissions-policy.
  Site URL: 127.0.0.1:80/dvwa/
  Method: GET
  Description: Suggested security header missing: permissions-policy.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
  Composite Score: -1

Finding 23
  Scanner: Nikto
  Title: Suggested security header missing: x-content-type-options.
  Site URL: 127.0.0.1:80/dvwa/
  Method: GET
  Description: Suggested security header missing: x-content-type-options.
  References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
  Composite Score: -1

Finding 24
  Scanner: Nikto
  Title: Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
  Site URL: 127.0.0.1:80/dvwa/
  Method: HEAD
  Description: Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
  References: -
  Composite Score: -1

Finding 25
  Scanner: Nikto
  Title: Appending '/./' to a directory allows indexing.
  Site URL: 127.0.0.1:80/dvwa/./
  Method: GET
  Description: Appending '/./' to a directory allows indexing.
  References: -
  Composite Score: -1

Finding 26
  Scanner: Nikto
  Title: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is
      no index page.
  Site URL: 127.0.0.1:80/dvwa//
  Method: GET
  Description: Apache on Red Hat Linux release 9 reveals the root directory listing by default if
      there is no index page.
  References: -
  Composite Score: -1

Finding 27
  Scanner: Nikto
  Title: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher.
  Site URL: 127.0.0.1:80/dvwa/%2e/
  Method: GET
  Description: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher.
  References: https://web.archive.org/web/20171102042459/http://www.securityfocus.com/bid/2513
  Composite Score: -1

Finding 28
  Scanner: Nikto
  Title: This might be interesting.
  Site URL:
    - 127.0.0.1:80/dvwa/css/
    - 127.0.0.1:80/dvwa/includes/
  Method: GET
  Description: This might be interesting.
  References: -
  Composite Score: -1

Finding 29
```

Scanner: Nikto
Title: The X-Content-Type-Options header is not set.
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: The X-Content-Type-Options header is not set. This could allow the user agent to
    render the content of the site in a different fashion to the MIME type.
References: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-t
    ype-header/
Composite Score: -1